



Software Engineering Institute
Carnegie Mellon University

Comments on U.S. Copyright Office (COLC) Notice: Section 1201 Study: Request for Additional Comments

FR 2016-23167

Docket ID: COLC-2015-0012-0088

Art Manion

CERT Coordination Center

amanion@cert.org

2016-10-27

About CERT

The CERT Coordination Center (CERT/CC) is part of the Software Engineering Institute (SEI), a Federally Funded Research and Development Center (FFRDC) at Carnegie Mellon University. The CERT/CC has been studying software security, specifically software security defects, or vulnerabilities, since its inception in 1988. The CERT/CC has significant experience in both the technological and institutional aspects of testing software for vulnerabilities and coordinating the results. The CERT/CC provided testimony regarding insufficient or unclear exemptions for security testing and the chilling effects of the DMCA on good-faith security research at a May 2003 hearing.

Comments

2. Proposed Amendments to Existing Permanent Exemptions

a. The Office is interested in commenters' views on whether this language [37 CFR 201.40 (b)(7)(i)] would be appropriate for adoption as a permanent exemption, or whether there are specific changes or additional provisions that Congress may wish to consider.

We offer two comments, intended as modifications to the current language before adopting it as a permanent exemption.

First, it's not clear why the violation of any applicable law and Computer Fraud and Abuse Act (CFAA) are called out. Do the CFAA and other laws not apply independently of this or any other DMCA exemption? The CFAA in particular is subject to active debate about its chilling effects on good-faith security research.¹

We suggest removing the text "...and does not violate any applicable law, including without limitation the Computer Fraud and Abuse Act of 1986, as amended and codified in title 18, United States Code" from 37 CFR 201.40 (b)(7)(i).

¹ <https://www.ischool.berkeley.edu/sites/default/files/cybersec-research-nsf-workshop.pdf>



Software Engineering Institute
Carnegie Mellon University

The second comment is about constraining research to three types of device or machine:

(A) A device or machine primarily designed for use by individual consumers (including voting machines);

(B) A motorized land vehicle; or

(C) A medical device designed for whole or partial implantation in patients or a corresponding personal monitoring system, that is not and will not be used by patients or for patient care.

How were these constraints chosen? What about airplanes, industrial control systems, enterprise information technology designed for professional use, or any other imaginable device or machine? We know of no device or machine (or, more specifically, the software that runs on them) that is immune from vulnerabilities and should not be open to good-faith security research. Furthermore, modern systems share software and hardware components. The same component used in a consumer device may also be used in a medical device, ground vehicle, or industrial control system.

We suggest that the critical distinction is that research is conducted safely – as implied in (C): “...that [the device] is not and will not be used by patients or for patient care.”

We recommend removing the “device or machine” constraints. It may be useful to add language requiring exempted, good-faith security research to be conducted safely, in test environments, and that test targets not be used in production if there is any concern about future performance and safety, as noted in (C). Such language, however, is already present in 37 CFR 201.40 (b)(7)(il): “...where such activity is carried out in a controlled environment designed to avoid any harm to individuals or the public.”